เอกสารประกอบการปฏิบัติการ

รายวิชา CP423324 Database and Web Security

Lab 10: XSS, Output Encoding and Secure Data Actions

วัตถุประสงค์

1. เพื่อให้นักศึกษาสามารถทดลองและอธิบายการเกิด Stored Cross-Site Scripting (Stored XSS) จากข้อมูลความคิดเห็นที่ถูกบันทึกไว้ในฐานข้อมูลได้
2. เพื่อให้นักศึกษาสามารถใช้ Output Encoding ด้วย htmlspecialchars() หรือฟังก์ชัน h() เพื่อป้องกัน XSS ใน HTML Output ได้อย่างเหมาะสม
3. เพื่อให้นักศึกษาสามารถอธิบายความแตกต่างระหว่าง Validation, Sanitization และ Output Encoding ได้
4. เพื่อให้นักศึกษาสามารถอธิบายความแตกต่างของบทบาทระหว่าง Prepared Statement และการป้องกัน XSS ได้อย่างถูกต้อง
5. เพื่อให้นักศึกษาสามารถใช้คำขอแบบ Method POST สำหรับการกระทำที่มีการเปลี่ยนแปลงข้อมูล เช่น การเพิ่ม การแก้ไข และการลบข้อมูลได้อย่างเหมาะสม
6. เพื่อให้นักศึกษาสามารถตรวจสอบความเป็นเจ้าของข้อมูล (Ownership) ของข้อมูลจาก created_by ก่อนอนุญาตให้แก้ไขหรือลบข้อมูลได้

คำชี้แจง

1. ให้นักศึกษา Capture ผลลัพธ์ตามที่งานของแต่ละข้อกำหนดลงใน Word และบันทึกไฟล์เป็น PDF โดยให้ตั้งชื่อว่า Lab10_รหัสนักศึกษา(มีขีด).pdf
2. เมื่อทำเสร็จเรียบร้อยแล้วให้แจ้งผู้ช่วยสอน (TA) เพื่อขอรับการตรวจและตอบคำถาม (กรุณาตรวจกับพี่ TA โดยคะแนนจะมาจากการตรวจในห้องเรียน)
3. เมื่อตรวจกับ TA เรียบร้อยแล้วให้นักศึกษาส่งใน Classroom เพื่อเป็นการสำรองข้อมูล
4. ไม่อนุญาตให้ส่งงานย้อนหลังได้ ยกเว้นกรณีลาป่วย หรืออุบัติเหตุ (ต้องมีใบรับรองแพทย์)

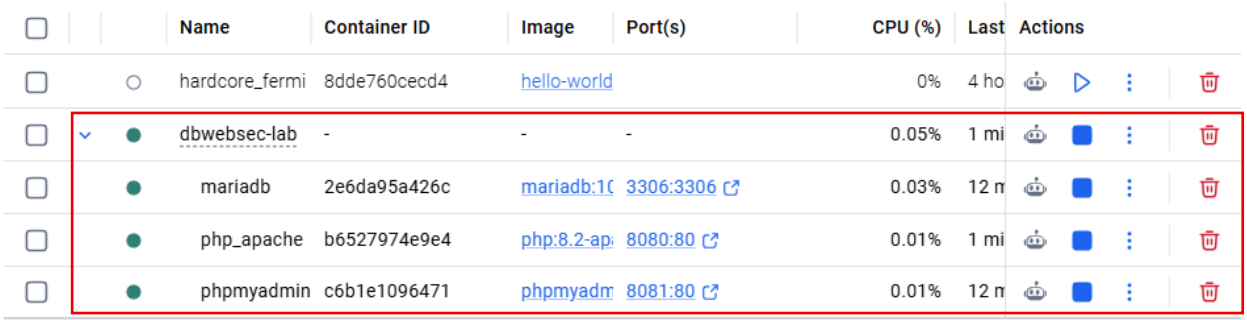
★★★★★★★★★

โจทย์ที่กำหนด

งานปฏิบัติการนี้ให้นักศึกษาพัฒนาเว็บแอปพลิเคชันต่อจากระบบข้อมูลหนังสือ จากLab09 โดยพัฒนาเพิ่มส่วน Book Comment / Review ซึ่งผู้ใช้สามารถเพิ่ม แสดง แก้ไข และลบความคิดเห็นได้ พร้อมปรับปรุงการแสดงผลเพื่อป้องกัน XSS และเพิ่มการตรวจสอบ Action เบื้องต้น

โดยมีขั้นตอนการพัฒนาระบบ ดังนี้

1. เปิด docker ที่เคยสร้างไว้ ให้ Start container name: dbwebsec-lab, mariadb, php_apache และ phpmyadmin



2. การใช้ฐานข้อมูลและตารางที่สร้างไว้ใน Lab08 โดยมีฐานข้อมูลชื่อ db_lab08 และสร้างตาราง book_comments เพื่อเก็บความคิดเห็นของหนังสือแต่ละเล่ม ซึ่งมีรายละเอียด ดังนี้

Field	Data Type	ข้อกำหนด	ความหมาย
id	INT	PRIMARY KEY, AUTO_INCREMENT	รหัสความคิดเห็น
book_id	INT	NOT NULL, FOREIGN KEY	รหัสหนังสือที่ความคิดเห็นอ้างถึง
created_by	VARCHAR(50)	NOT NULL	ผู้สร้างหรือเจ้าของความคิดเห็น
comment	TEXT	NOT NULL	ข้อความความคิดเห็น
created_at	DATETIME	NOT NULL, DEFAULT CURRENT_TIMESTAMP	วันที่และเวลาที่บันทึกความคิดเห็น

ตัวอย่างคำสั่ง SQL

สร้างฐานข้อมูล db_lab08

```
CREATE DATABASE IF NOT EXISTS db_lab08
CHARACTER SET utf8mb4
COLLATE utf8mb4_unicode_ci;
```

สร้างตาราง book_comments

```
CREATE TABLE IF NOT EXISTS book_comments (
    id INT AUTO_INCREMENT PRIMARY KEY,
    book_id INT NOT NULL,
    created_by VARCHAR(50) NOT NULL,
    comment TEXT NOT NULL,
    created_at DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP,
    CONSTRAINT fk_book_comments_book
        FOREIGN KEY (book_id) REFERENCES books(id)
        ON DELETE CASCADE
);
```

ผลลัพธ์จากการสร้างตาราง book_comments ดังนี้

Name	Type	Collation	Attributes	Null	Default	Comments	Extra
id	int(11)			No	*None*		AUTO_INCREMENT
book_id	int(11)			No	*None*		
created_by	varchar(50)	utf8mb4_unicode_ci		No	*None*		
comment	text	utf8mb4_unicode_ci		No	*None*		
created_at	datetime			No	current_timestamp()		

จากนั้นเพิ่มข้อมูลในตาราง book_comments ด้วยคำสั่ง SQL ดังนี้

```
INSERT INTO book_comments (book_id, created_by, comment) VALUES
(1, 'student01', 'The content is easy to understand and useful for review.'),
(1, 'student02', 'The database examples are clear and easy to follow.'),
(3, 'student02', 'This book is useful for beginners in Web Security.');
```

ผลลัพธ์จากการการเพิ่มข้อมูล ดังนี้

id	book_id	created_by	comment	created_at
1	1	student01	The content is easy to understand and useful for r...	2026-09-11 10:33:16
2	1	student02	The database examples are clear and easy to follow...	2026-09-11 10:33:16
3	3	student02	This book is useful for beginners in Web Security.	2026-09-11 10:33:16

ใน Lab นี้จำลองผู้ใช้ปัจจุบันเป็น student01 เพื่อใช้สาธิตการตรวจสอบความเป็นเจ้าของข้อมูล (Ownership) เท่านั้น ไม่ใช่ระบบ Authentication

3. การสร้างเว็บแอปพลิเคชัน

ให้นักศึกษาสร้างโฟลเดอร์ Lab10 ไว้ภายใน C:\dbwebsec-lab\www สำหรับไฟล์ที่ต้องสร้างมีไฟล์ทั้งหมด 8 ไฟล์ มีรายละเอียด ดังนี้

1) Lab10_config.php เชื่อมต่อฐานข้อมูลด้วย webapp_user

2) Lab10_comments_insecure.php หน้าแสดงและเพิ่มความคิดเห็น โดยจงใจแสดง Comment โดยไม่ทำ Output Encoding

3) Lab10_comments_secure.php หน้าแสดงและเพิ่มความคิดเห็น โดยใช้ Output Encoding เพื่อป้องกัน XSS (นักศึกษาสร้างเอง)

4) Lab10_add_comment.php รับข้อมูลจาก Add Comment Form ด้วย Method POST และบันทึกความคิดเห็นลงฐานข้อมูลด้วย Prepared Statement

5) Lab10_edit_form.php แสดงแบบฟอร์มแก้ไขความคิดเห็น โดยดึงข้อมูล Comment ที่เลือกมาแสดง และตรวจสอบความเป็นเจ้าของข้อมูล (Ownership) เบื้องต้น

6) Lab10_edit_comment.php รับข้อมูลที่แก้ไขด้วย Method POST แล้วตรวจสอบ Input และความเป็นเจ้าของข้อมูล (Ownership) ก่อนอัปเดตข้อมูลด้วย Prepared Statement

7) Lab10_delete_comment.php รับคำขอลบความคิดเห็นด้วย Method POST และตรวจสอบความเป็นเจ้าของข้อมูล (Ownership) และ CSRF Token ก่อนลบข้อมูล (นักศึกษาสร้างเอง)

8) Lab10_fake_request.html ไฟล์สำหรับทดสอบคำขอจากเว็บไซต์ภายนอกเพื่อทดสอบการโจมตีแบบ CSRF กับ Lab10_delete_comment.php (เตรียมไว้ให้)

3.1 การสร้างไฟล์ Lab10_config.php โดยมีคำสั่ง ดังนี้

```php
<?php
declare(strict_types=1);
session_start();
date_default_timezone_set('Asia/Bangkok');
const DB_HOST='db';
const DB_PORT=3306;
const DB_NAME='db_lab08';
const DB_USER='webapp_user';
const DB_PASS='WebApp1234';
mysqli_report(MYSQLI_REPORT_ERROR | MYSQLI_REPORT_STRICT);
try {
    $conn=new mysqli(DB_HOST,DB_USER,DB_PASS,DB_NAME,DB_PORT);
    $conn->set_charset('utf8mb4');
    $conn->query("SET time_zone = '+07:00'");
} catch (mysqli_sql_exception $e) {
    http_response_code(500);
    error_log($e->getMessage());
    exit('Database connection failed.');
}
function h(?string $value): string {
    return htmlspecialchars($value ?? '',
    ENT_QUOTES | ENT_SUBSTITUTE, 'UTF-8');
}
$_SESSION['username'] ??= 'student01';
$currentUser=$_SESSION['username'];

if (empty($_SESSION['csrf_token'])) {
    $_SESSION['csrf_token']=bin2hex(random_bytes(32));
}
```

3.2 สร้างไฟล์ Lab10_comments_insecure.php ไฟล์นี้ ใช้เพื่อสาธิตการ INSERT ที่แสดง Comment โดยไม่ทำ Output Encoding เพื่อให้เห็นว่าการป้องกัน SQL Injection ไม่ได้ป้องกัน XSS ให้ทดลองเฉพาะในระบบ Lab นี้เท่านั้น

```php
<?php
require_once 'Lab10_config.php';
$books = $conn->query('SELECT id,title FROM books ORDER BY title');
$result = $conn->query("SELECT c.id,c.book_id,b.title,c.created_by,
c.comment,c.created_at FROM book_comments c
JOIN books b ON b.id=c.book_id
ORDER BY c.id DESC");
$message = $_GET['message'] ?? '';
?>
<!doctype html>
<html lang="en">
<head>
    <meta charset="utf-8">
    <title>Book Comments - XSS Vulnerable Version</title>
    <style>
        body {
            font-family: Arial, sans-serif;
            max-width: 900px;
            margin: 32px auto;
            line-height: 1.5;
            padding: 0 16px
        }
        .subtle,
        .meta {
            color: #666
        }
        .notice,
        .add-form,
        .comment-card {
            border: 1px solid #ccc;
            border-radius: 6px;
            padding: 16px;
            margin-bottom: 16px
        }
```

```
        label {
            display: block;
            font-weight: bold;
            margin-top: 10px
        }
        select,
        textarea {
            width: 100%;
            box-sizing: border-box;
            padding: 8px
        }
        button,
        .button-link {
            display: inline-flex;
            align-items: center;
            justify-content: center;
            width: 110px;
            height: 40px; padding: 0;
            margin: 0;  border: 1px solid #888;
            background: #f5f5f5;
            color: #111;
            font-family: Arial, sans-serif;
            font-size: 14px;  line-height: 1;
            white-space: nowrap;   text-decoration: none;
            border-radius: 4px; box-sizing: border-box;
            cursor: pointer;
        }
        .actions {
            display: flex;
            gap: 8px;
            align-items: center;
            margin-top: 10px
        }
        .actions form {
            display: inline;
            margin: 0
        }
    </style>
</head>

```

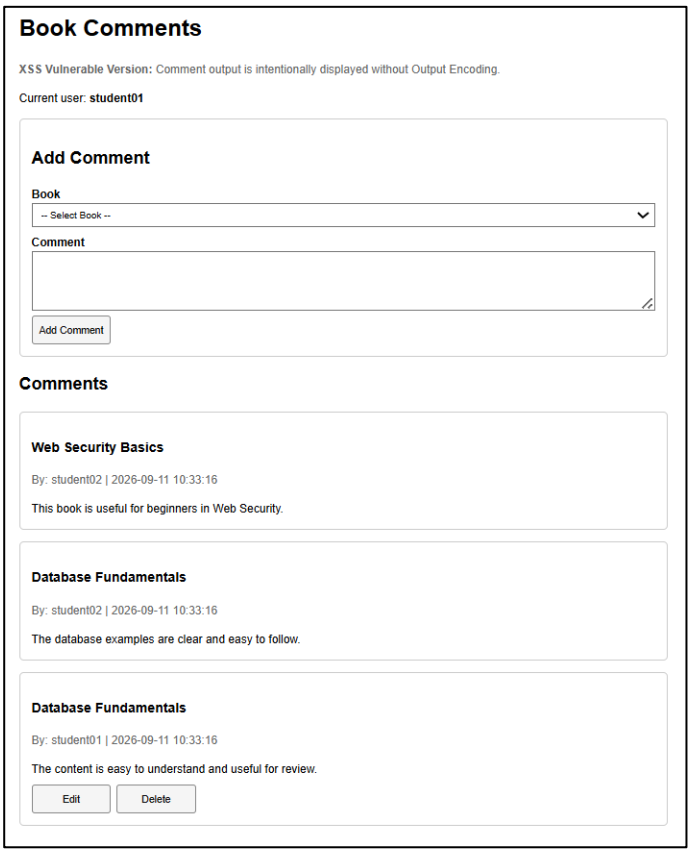
```
<body>
    <h1>Book Comments</h1>
    <p class="subtle"><strong>XSS Vulnerable Version:</strong>
    Comment output is intentionally displayed without Output Encoding.</p>
    <p>Current user: <strong><?= h($currentUser) ?></strong></p>
    <?php if ($message !== ''): ?>
        <div class="notice"><?= h($message) ?></div>
    <?php endif; ?>
    <section class="add-form">
        <h2>Add Comment</h2>
        <form method="post" action="Lab10_add_comment.php">
            <input type="hidden" name="return_to" value="Lab10_comments_insecure.php">
            <label for="book_id">Book</label>
            <select name="book_id" id="book_id" required>
                <option value="">-- Select Book --</option>
                <?php while ($book = $books->fetch_assoc()): ?>
                    <option value="<?= (int)$book['id'] ?>">
                        <?= h($book['title']) ?>
                    </option><?php endwhile; ?>
            </select>
            <label for="comment">Comment</label>
            <textarea name="comment" id="comment" maxlength="500" rows="4" required>
            </textarea>
            <button type="submit">Add Comment</button>
        </form>
    </section>
    <h2>Comments</h2>
    <?php while ($row = $result->fetch_assoc()): ?><article class="comment-card">
            <h3><?= h($row['title']) ?></h3>
            <p class="meta">
                By: <?= h($row['created_by']) ?> | <?= h($row['created_at']) ?>
              </p>
            <div><?= $row['comment'] ?></div>
            <?php if ($row['created_by'] === $currentUser): ?><div class="actions">
                    <a class="button-link" href="Lab10_edit_form.php?id=<?= (int)$row['id'] ?>">
                        Edit</a>
                    <form method="post" action="Lab10_delete_comment.php"
                      onsubmit="return confirm('Delete this comment?');">
                        <input type="hidden" name="comment_id" value=
                        "<?= (int)$row['id'] ?>">
                        <input type="hidden" name="csrf_token" value=
                        "<?= h($_SESSION['csrf_token']) ?>">
                        <input type="hidden" name="return_to" value="Lab10_comments_insecure.php">
                        <button type="submit">Delete</button>
                    </form>
                </div><?php endif; ?>
        </article><?php endwhile; ?>
</body>
</html>
```

3.3 สร้างไฟล์ Lab10_add_comment.php ไฟล์คำสั่งในการเพิ่มข้อมูลในฐานข้อมูล

```php
<?php
require_once 'Lab10_config.php';
if ($_SERVER['REQUEST_METHOD'] !== 'POST') {
    http_response_code(405);
    exit('Method not allowed.');
}
$bookId = filter_input(INPUT_POST, 'book_id', FILTER_VALIDATE_INT);
$comment = trim($_POST['comment'] ?? '');
$returnTo = $_POST['return_to'] ?? 'Lab10_comments_insecure.php';
$allowed = ['Lab10_comments_insecure.php', 'Lab10_comments_secure.php'];
if (!in_array($returnTo, $allowed, true))
    $returnTo = 'Lab10_comments_insecure.php';
if (!$bookId || $comment === '') {
    header('Location: ' . $returnTo . '?message=' .
    urlencode('Please select a book and enter a comment.'));
    exit;
}
$stmt = $conn->prepare('INSERT INTO book_comments (book_id,created_by,comment)
      VALUES (?,?,?)');
$stmt->bind_param('iss', $bookId, $currentUser, $comment);
$stmt->execute();
header('Location: ' . $returnTo . '?message=' . urlencode('Comment saved.'));
exit;
```

งานที่ 1.1 ทดสอบไฟล์ Lab10_comments_insecure.php

1) เปิด URL: http://localhost:8080/Lab10/Lab10_comments_insecure.php



2) เลือก Book หนึ่งเล่ม และกรอก Comment ต่อไปนี้
HTML Test
แล้วกด Add Comment แล้วสังเกตผลลัพธ์
3) Capture หน้าจอ Browser และข้อมูลในฐานข้อมูล
4) จากนั้น เลือก Book หนึ่งเล่ม และกรอก Comment ต่อไปนี้
<script>alert('Stored XSS')</script>
แล้วกด Add Comment แล้วสังเกตผลลัพธ์
5) Capture หน้าจอ Browser และข้อมูลในฐานข้อมูล

3.4 สร้างไฟล์ Lab10_comments_secure.php โดยคัดลอกจาก Lab10_comments_insecure.php แล้วปรับการแสดงผล Comment ด้วย Output Encoding (นักศึกษาสร้างเอง)

งานที่ 1.2 ทดสอบไฟล์ Lab10_comments_secure.php
1) เปิด URL: http://localhost:8080/Lab10/Lab10_comments_secure.php
Capture หน้าจอ Browser
2) เลือก Book หนึ่งเล่ม และกรอก Comment ต่อไปนี้
HTML Test
แล้วกด Add Comment แล้วสังเกตผลลัพธ์
3) Capture หน้าจอ Browser และข้อมูลในฐานข้อมูล
4) จากนั้น เลือก Book หนึ่งเล่ม และกรอก Comment ต่อไปนี้
<script>alert('Stored XSS')</script>
แล้วกด Add Comment แล้วสังเกตผลลัพธ์
5) Capture หน้าจอ Browser และข้อมูลในฐานข้อมูล

3.5 ให้สร้างไฟล์ Lab10_edit_form.php ไฟล์นี้เป็นหน้าจอที่แสดงการแก้ไขข้อมูล โดยดึงข้อมูลของ comment ที่เลือกมาแสดงเฉพาะ แล้วผู้ใช้แก้ไข จะสามารถบันทึกได้ มีคำสั่งดังนี้

```php
<?php
require_once 'Lab10_config.php';
$id = filter_input(INPUT_GET, 'id', FILTER_VALIDATE_INT);
if (!$id) {
    http_response_code(400);
    exit('Invalid request.');
}
$stmt = $conn->prepare("SELECT c.id,b.title,c.created_by,c.comment
FROM book_comments c JOIN books b ON b.id=c.book_id WHERE c.id=?");
$stmt->bind_param('i', $id);
$stmt->execute();
$comment = $stmt->get_result()->fetch_assoc();
if (!$comment) {
    http_response_code(404);
    exit('Comment not found.');
}
if ($comment['created_by'] !== $currentUser) {
    http_response_code(403);
    exit('Access denied.');
}
?>

<!doctype html>
<html lang="en">
<head>
    <meta charset="utf-8">
    <title>Edit Comment</title>
    <style>
        body {
            font-family: Arial, sans-serif;
            max-width: 900px;
            margin: 32px auto;
            line-height: 1.5;
            padding: 0 16px
        }
        .subtle,
        .meta {
            color: #666
        }
        .notice,
        .add-form,
        .comment-card {
            border: 1px solid #ccc;
            border-radius: 6px;
            padding: 16px;
            margin-bottom: 16px
        }
```

```
        label {
            display: block;
            font-weight: bold;
            margin-top: 10px
        }
        select,
        textarea {
            width: 100%;
            box-sizing: border-box;
            padding: 8px
        }
        button,
        .button-link {
            display: inline-flex;
            align-items: center;
            justify-content: center;
            width: 110px;
            height: 40px; padding: 0;
            margin: 0;  border: 1px solid #888;
            background: #f5f5f5;
            color: #111;
            font-family: Arial, sans-serif;
            font-size: 14px;  line-height: 1;
            white-space: nowrap;   text-decoration: none;
            border-radius: 4px; box-sizing: border-box;
            cursor: pointer;
        }

         .actions {
            display: flex;
            gap: 8px;
            align-items: center;
            margin-top: 10px
         }
         .actions form {
            display: inline;
            margin: 0
         }
    </style>
</head>

<body>
    <h1>Edit Comment</h1>
    <div class="comment-card">
        <p><strong>Book:</strong> <?= h($comment['title']) ?></p>
        <p><strong>Created by:</strong> <?= h($comment['created_by']) ?></p>
        <form method="post" action="Lab10_edit_comment.php">
            <input type="hidden" name="comment_id" value="<?= (int)$comment['id'] ?>">
            <label for="comment">Comment</label>
            <textarea name="comment" id="comment"
                maxlength="500" rows="5" required><?= h($comment['comment']) ?>
            </textarea>
            <button type="submit">Save Changes</button>
            <a class="button-link" href="Lab10_comments_secure.php">Cancel</a>
        </form>
    </div>
</body>
</html>
```

3.6 ให้สร้างไฟล์ Lab10_edit_comment.php ไฟล์นี้เป็นตัวอย่าง Secure Action Pattern โดยตรวจ POST, Input, การมีอยู่ของข้อมูล และตรวจสอบความเป็นเจ้าของข้อมูล (Ownership) ผ่าน created_by ก่อน UPDATE โดยยังไม่สร้าง Role user/admin

```php
<?php
require_once 'Lab10_config.php';
if ($_SERVER['REQUEST_METHOD'] !== 'POST') {
    http_response_code(405);
    exit('Method not allowed.');
}
$id = filter_input(INPUT_POST, 'comment_id', FILTER_VALIDATE_INT);
$newComment = trim($_POST['comment'] ?? '');
if (!$id || $newComment === '') {
    http_response_code(400);
    exit('Invalid request.');
}
$stmt = $conn->prepare('SELECT id,created_by
                        FROM book_comments WHERE id=?');
$stmt->bind_param('i', $id);
$stmt->execute();
$comment = $stmt->get_result()->fetch_assoc();
if (!$comment) {
    http_response_code(404);
    exit('Comment not found.');
}
if ($comment['created_by'] !== $currentUser) {
    http_response_code(403);
    exit('Access denied.');
}
$stmt = $conn->prepare('UPDATE book_comments SET comment=? WHERE id=?');
$stmt->bind_param('si', $newComment, $id);
$stmt->execute();
header('Location: Lab10_comments_secure.php?message='
    . urlencode('Comment updated.'));
exit;
```

งานที่ 2.1 ทดสอบการแก้ไขข้อมูล

1) เปิด http://localhost:8080/Lab10/Lab10_comments_secure.php

แล้วคลิกเลือกปุ่ม Edit ของ comment ของ student01

2) Capture หน้าจอผลลัพธ์ เมื่อไปยังหน้า Lab10_edit_form.php

3) จากนั้นให้แก้ไข comment: <h1>Edit Test</h1>

แล้วกดปุ่ม Save Change แล้ว Capture หน้าจอผลลัพธ์ และข้อมูลในฐานข้อมูล

3.7 สร้างไฟล์ Lab10_delete_comment_before_csrf.php โดยมีคำสั่ง ดังนี้

```php
<?php
require_once 'Lab10_config.php';
if ($_SERVER['REQUEST_METHOD'] !== 'POST') {
    http_response_code(405);
    exit('Method not allowed.');
}
$id = filter_input(INPUT_POST, 'comment_id', FILTER_VALIDATE_INT);
$returnTo = $_POST['return_to'] ?? 'Lab10_comments_secure.php';
$allowed = ['Lab10_comments_insecure.php', 'Lab10_comments_secure.php'];
if (!in_array($returnTo, $allowed, true))
    $returnTo = 'Lab10_comments_secure.php';
if (!$id) {
    http_response_code(400);
    exit('Invalid request.');
}
$stmt = $conn->prepare('SELECT id,created_by
                        FROM book_comments WHERE id=?');
$stmt->bind_param('i', $id);
$stmt->execute();
$comment = $stmt->get_result()->fetch_assoc();
if (!$comment) {
    http_response_code(404);
    exit('Comment not found.');
}
if ($comment['created_by'] !== $currentUser) {
    http_response_code(403);
    exit('Access denied.');
}
$stmt = $conn->prepare('DELETE FROM book_comments WHERE id=?');
$stmt->bind_param('i', $id);
$stmt->execute();
header('Location: ' . $returnTo . '?message=' . urlencode('Comment deleted.'));
exit;
```

งานที่ 2.2 ทดสอบการลบข้อมูล

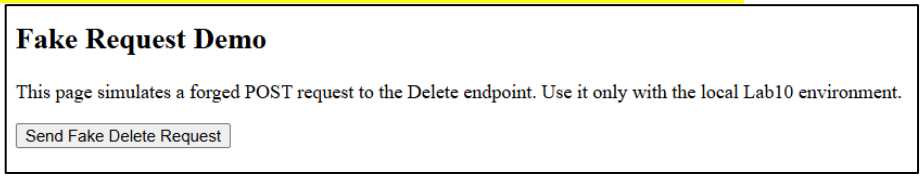
1) เปิด http://localhost:8080/Lab10/Lab10_comments_secure.php

แล้วคลิกเลือกปุ่ม Delete ของ comment ของ student01

2) Capture หน้าจอผลลัพธ์ และข้อมูลในฐานข้อมูล

งานที่ 3.1 ทดสอบการลบข้อมูลจากเว็บไซต์ภายนอก

1) เปิด http://localhost:8080/Lab10/Lab10_fake_request.html



แล้วคลิกเลือกปุ่ม Send Fake Delete Request

2) Capture หน้าจอผลลัพธ์ และข้อมูลในฐานข้อมูล

3.8 สร้างไฟล์ Lab10_delete_comment.php ให้นักศึกษาเขียนเอง

งานที่ 3.2 ทดสอบการลบข้อมูลจากเว็บไซต์ภายนอกที่มีการป้องกัน CSRF

1) เปิดไฟล์ Lab10_fake_request.html แล้วแก้ไขคำสั่งของ Form ส่วน action ดังนี้
   action=http://localhost:8080/Lab10/Lab10_delete_comment.php
   และแก้ไข <input type="hidden" name="feedback_id" value="1">
   เปลี่ยน value="2"
   แล้ว Save
2) จากนั้นเปิดURL http://localhost:8080/Lab10/Lab10_fake_request.html
แล้วคลิกเลือกปุ่ม Send Fake Delete Request

3) Capture หน้าจอผลลัพธ์ และข้อมูลในฐานข้อมูล